

E-Commerce — Payments, Security & Legal Issues

Class Notes: Classes 07–09

Part I • Section EC-3 • Payment Systems & Security

CO3 — Ethical Issues & Remedies

CO4 — Apply E-Commerce Technologies

Bloom's: Understand → Analyze

Classes 07–09 of 39

CONTENTS

- 07 [E-Commerce Payment Systems](#)
- 08 [E-Commerce Security: Encryption & Protocols](#)
- 09 [E-Commerce Threats, Ethics & Legal Issues](#)

Payment is the moment of truth in every e-commerce transaction — the point where intent becomes revenue. A payment system that is slow, unreliable, untrustworthy, or unavailable in the buyer's preferred method will destroy conversion and drive customers to competitors. Understanding how online payments work — from the roles of different participants to the flow of funds to the security mechanisms — is fundamental for any e-commerce practitioner or manager.

1. The Online Payment Ecosystem: Participants and Roles

Every online card transaction involves at least five distinct parties, each playing a specific role. Students frequently confuse these roles — careful attention is required.

Participant	Role	Examples	Who They Serve
Cardholder	The customer — the person making the purchase using a credit or debit card	Any consumer with a Visa/Mastercard/bKash account	Themselves — initiates the payment
Merchant	The seller — the e-commerce business accepting the payment	Daraz, Chaldal, any online store	Their customers — facilitates the purchase
Issuing Bank (Issuer)	The bank that issued the cardholder's credit or debit card. Authorizes or declines transactions on behalf of the cardholder. Assumes the credit risk for credit card transactions.	Dutch-Bangla Bank (DBBL) issuing a Nexus card, BRAC Bank issuing a Visa, City Bank issuing an Amex	The cardholder — protects them against fraud, approves credit
Acquiring Bank (Acquirer)	The merchant's bank — the financial institution that maintains the merchant's account and processes card payments on the merchant's behalf. Receives settlement funds and deposits them to the merchant's account. Takes on the risk of merchant fraud.	Eastern Bank Ltd. (merchant acquiring in Bangladesh), Brac Bank merchant services	The merchant — enables them to accept card payments
Card Network (Scheme)	Sets the rules, standards, and interchange rates for all transactions on its network. Routes transaction messages between issuing and acquiring banks. Does NOT directly hold funds — it is a communication and rules network.	Visa, Mastercard, American Express, UnionPay (China), JCB (Japan)	Both banks — provides the rails that connect them

Participant	Role	Examples	Who They Serve
Payment Gateway	Technology infrastructure that captures payment data from the merchant's website, encrypts it, and securely transmits it to the payment processor. The "point of sale terminal" of e-commerce — the technical bridge between the merchant's checkout and the banking system.	SSL Commerz (Bangladesh), Stripe (global), PayPal, Braintree, Adyen	The merchant — handles technical complexity of payment acceptance
Payment Processor	Processes the actual transaction — routes authorization requests to the appropriate card network and issuing bank, and returns approval/decline responses. Sometimes the same entity as the payment gateway.	First Data, TSYS, Worldpay, Square; in Bangladesh: SSLC, PortWallet	Both merchants and banks — handles transaction routing

KEY DISTINCTION: GATEWAY VS. PROCESSOR VS. ACQUIRER

The **payment gateway** is the technology interface (captures and encrypts card data). The **payment processor** routes the transaction through banking networks. The **acquiring bank** holds the merchant's account and settles funds. In practice, many providers bundle these three functions — Stripe acts as gateway + processor + acquirer. But understanding the distinct roles explains why fees have multiple components: gateway fee + interchange fee + acquirer fee.

2. Credit/Debit Card Processing Flow: Authorization → Clearing → Settlement

A card payment happens in two distinct phases — **authorization** (real-time, seconds) and **clearing and settlement** (batch process, 1–3 business days). Students must understand both phases and the distinction between them.

PHASE 1: AUTHORIZATION (REAL-TIME — 2–8 SECONDS)

1 Customer Enters Card Customer enters card details on merchant checkout page. Payment gateway immediately encrypts the data (TLS + tokenization) and transmits to payment processor.	2 Processor → Card Network Payment processor identifies the card network (Visa/Mastercard from the BIN — first 6 digits of card number) and routes the authorization request through the card network.	3 Card Network → Issuing Bank Card network (Visa/Mastercard) routes the authorization request to the issuing bank (cardholder's bank). Message contains: card number, amount, merchant ID, currency.	4 Issuer Decision Issuing bank checks: (a) sufficient funds/credit limit; (b) card not reported stolen/blocked; (c) fraud score within acceptable range; (d) cardholder not flagged. Returns Approve (with authorization code)
--	---	---	---

or Decline (with reason code).

5

Response Back

Authorization response travels back: Issuer → Card Network → Processor → Gateway → Merchant. Merchant receives Approve/Decline in 2–8 seconds. Order is confirmed (or rejected) to the customer.

WHAT AUTHORIZATION DOES NOT DO

Authorization only *reserves* the funds — it does not transfer money. The cardholder's available balance is reduced (hold placed), but the actual money does not move until settlement. This is why hotel pre-authorizations can temporarily reduce your available balance without an actual charge.

PHASE 2: CLEARING AND SETTLEMENT (BATCH — 1–3 BUSINESS DAYS)

1 Batch Submission (Clearing)

At end of business day, the merchant's payment processor submits a batch file containing all the day's authorized transactions to the card network. This is called "batching out" or "closing the batch." The authorization codes from Phase 1 are matched with the actual transaction amounts.

2 Interchange

The card network calculates **interchange fees** — fees paid by the acquiring bank to the issuing bank for each transaction. Interchange rates vary by card type (premium rewards cards charge higher interchange), transaction type (card-present vs. card-not-present), and merchant category. For e-commerce (card-not-present), interchange is typically 1.5–3.5% of transaction value because the fraud risk is higher than in-person transactions.

3 Settlement

The acquiring bank transfers the net funds (transaction amount minus fees) to the merchant's bank account. Simultaneously, the issuing bank posts the charges to the cardholder's statement. The card network receives its own assessment fees from both banks. Typical settlement timing: T+1 to T+3 business days (transaction day + 1–3 days). This delay is why new merchants often face cash flow challenges — they fulfill orders immediately but receive funds days later.

FEE STRUCTURE IN CARD PAYMENTS

Merchant Discount Rate (MDR) = Interchange Fee + Card Network Fee + Acquirer Margin

// Total % deducted from transaction before merchant receives funds

Typical MDR in Bangladesh: 1.5% – 2.5% for domestic debit/credit cards

Typical MDR for international cards: 2.5% – 3.5%

Example: 1,000 BDT sale × 2% MDR → Merchant receives 980 BDT

3. Digital Wallets and Tokenization

DIGITAL WALLET

A **digital wallet** (also called e-wallet or mobile wallet) is a software-based system that stores payment information and passwords for numerous payment methods and websites, allowing users to complete purchases easily and quickly without re-entering card details for every transaction. It acts as a digital equivalent of a physical wallet.

MAJOR DIGITAL WALLET TYPES

- ▶ **PayPal:** The original internet payment wallet (founded 1998). Users store card or bank account details in their PayPal account. When paying on a merchant site, they authenticate with PayPal credentials — the merchant never sees card details. PayPal assumes the payment risk and settles with the merchant. Used in 200+ countries; 400M+ active accounts globally. Strong buyer protection (dispute resolution, refunds) is a key trust driver. PayPal is also a payment processor, issuing bank, and wallet simultaneously.
- ▶ **Google Pay (GPay):** Stores debit/credit cards in Google's secure cloud. Uses tokenization — a unique device-specific token replaces the actual card number for each transaction. Works online (one-tap checkout via Google Pay API) and in-store (NFC tap-to-pay). Syncs across all Android devices logged into the same Google account.
- ▶ **Apple Pay:** iOS/macOS equivalent of Google Pay. Stores cards in the Secure Element (a dedicated chip on iPhone). Uses Touch ID or Face ID for biometric authentication. Generates a one-time dynamic security code for each transaction — even if intercepted, the code cannot be reused. Never sends the actual card number to merchants.
- ▶ **bKash (Bangladesh):** Bangladesh's dominant Mobile Financial Service (MFS). Registered users store funds in their bKash account (linked to mobile number). Merchants integrate bKash via API to accept payment. bKash Payment Gateway allows any e-commerce site to display a "Pay with bKash" button. 60M+ registered accounts as of 2023. Transaction flow: customer enters bKash number → receives PIN prompt → confirms payment → merchant receives real-time notification. Also supports QR code payment. Key for serving the unbanked population — users need only a mobile phone, not a bank account.

- **Nagad (Bangladesh):** Bangladesh Post Office's digital financial service, launched 2019. Government-backed competitor to bKash. Simpler account opening (no physical visit required). Competitive transaction fees — lower merchant discount rate than bKash, driving adoption among price-sensitive merchants. 70M+ registered users (2023).

TOKENIZATION — HOW DIGITAL WALLETS PROTECT CARD DATA

TOKENIZATION

Tokenization is the process of replacing sensitive data (like a 16-digit card number — the Primary Account Number or PAN) with a non-sensitive substitute called a **token**. The token looks like a card number but has no value if stolen — it can only be used in the specific context for which it was generated (a specific merchant, a specific device, or a specific transaction).



Customer's Actual Card: 4532 8765 1234 5678

Real PAN (Primary Account Number) — never transmitted to the merchant in modern wallets



Token Generation by Tokenization Service (card network or wallet)

Real PAN is stored in the Token Vault. A unique, random token is generated: e.g., 9273 4651 8820 1047 — cryptographically bound to this merchant + device combination



Merchant Receives Token: 9273 4651 8820 1047

Merchant stores and charges the token, never the real card number. Even if the merchant's database is breached, attackers get worthless tokens — the real card number is safe in the token vault controlled by the card network or wallet provider.

4. Mobile Payments: NFC and QR-Code Based Systems

Mobile payment means paying using a smartphone instead of cash or physical cards.

NFC — NEAR FIELD COMMUNICATION

NFC PAYMENT

NFC (Near Field Communication) is a short-range (4 cm or less) wireless communication standard that enables two devices to exchange data when brought into close proximity. In payments, the customer's NFC-enabled smartphone or contactless card communicates with the merchant's NFC-enabled payment terminal in under a second — a "tap to pay" interaction.

- **How it works technically:** The customer's device (with Apple Pay, Google Pay, or contactless card) generates a one-time cryptographic token for the transaction. When tapped against the terminal, this token plus the transaction amount is transmitted via NFC radio waves. The terminal routes this to the

acquiring bank as a standard card transaction — the backend processing is identical to a chip card transaction.

- ▶ **Security:** The 4cm range limits eavesdropping — an attacker would need to be physically adjacent. Dynamic tokenization means the card number is never transmitted. Biometric authentication (Face ID, fingerprint) adds a second factor. Practically more secure than chip+PIN for most fraud scenarios.
- ▶ **Bangladesh context:** NFC-capable point-of-sale terminals are available in major Dhaka and Chattogram supermarkets, malls, and hotels. However, penetration is limited compared to South Korea, UK, or Australia where 80%+ of in-person transactions are contactless. Smartphone NFC payments require NFC hardware — common in mid-range and premium Android phones and all iPhones since iPhone 6.
- ▶ **Contactless card limit:** Central banks set transaction limits for contactless card payments without PIN — in Bangladesh, typically BDT 3,000 per contactless transaction. Higher amounts require PIN entry.

QR CODE-BASED PAYMENTS

QR PAYMENT

A QR (Quick Response) code payment uses a two-dimensional barcode that encodes payment information. The customer scans the merchant's QR code using their mobile app camera to initiate a payment, or the merchant scans the customer's QR code. No NFC hardware required — any smartphone with a camera can participate.

- ▶ **Merchant-presented QR (most common in Bangladesh):** The merchant displays a static or dynamic QR code at the counter or on the payment screen. The customer opens their bKash/Nagad/bank app, scans the code, enters the amount (for static QR) or confirms the pre-filled amount (for dynamic QR), enters PIN, and confirms. Funds are transferred in real-time. Receipt via SMS/app notification.
- ▶ **Customer-presented QR:** The customer displays their personal QR code (from their payment app) and the merchant's POS device scans it. Used in some retail environments in China (Alipay, WeChat Pay) and increasingly in Bangladesh corporate environments.
- ▶ **UPI — Unified Payments Interface (India):** India's QR + real-time payment system, operated by NPCI (National Payments Corporation of India). UPI allows instant bank-to-bank transfer via QR scan, phone number, or UPI ID. Processes 10+ billion transactions/month (2023). Relevant as a model Bangladesh is studying — Bangladesh Bank's Binimoy system is modeled partly on UPI concepts.
- ▶ **USSD-based payments:** For feature phones without internet or camera — payments via short code menu (*247# for bKash). Critical for rural Bangladesh where smartphone penetration is lower. Enables financial inclusion in the most basic phone environments.
- ▶ **Advantages of QR over NFC:** Lower cost — no special terminal hardware; works on any smartphone; can be printed on paper. Dominant in Southeast Asia and South Asia. Disadvantage: slightly more steps than

tap-to-pay NFC; susceptible to QR code tampering (a criminal replaces the merchant's QR sticker with their own QR — always check the account name before confirming payment).

5. Buy Now Pay Later (BNPL)

BNPL DEFINITION

Buy Now Pay Later (BNPL) is a short-term financing product that allows consumers to purchase immediately and pay in installments — typically 3–6 equal payments over weeks or months — usually with zero interest if paid on time. BNPL is offered at the point of checkout as an alternative to credit cards.

BNPL BUSINESS MODEL

- ▶ **Merchant pays, not consumer:** In the standard BNPL model, the BNPL provider charges the merchant a fee (typically 2–8% of transaction value) in exchange for the BNPL provider immediately paying the merchant in full. The consumer pays the BNPL provider in installments.
- ▶ **Revenue streams for BNPL provider:** (a) Merchant fees (primary); (b) Late payment fees charged to consumers who miss installments; (c) Interest on longer-term financing products (for plans beyond 6 months); (d) Data monetization — BNPL providers accumulate detailed consumer purchase behavior data.
- ▶ **Why merchants pay:** BNPL dramatically increases average order value (AOV) — consumers spend 20–30% more when they can spread payments. Conversion rate also increases — purchase anxiety about large one-time payments is reduced. The merchant's revenue uplift justifies the BNPL fee.
- ▶ **Major BNPL providers globally:** Klarna (Sweden), Afterpay/Clearpay (Australia/UK), Affirm (US), Zip. Apple Pay Later launched by Apple in 2023. Shopify also launched its own BNPL.
- ▶ **Bangladesh context:** BNPL is nascent in Bangladesh — some banks offer EMI (Equated Monthly Installment) plans on credit cards for electronics purchases (6/12/24 month 0% EMI on specific partner merchants). Formal BNPL products (Klarna-style) are not yet widespread but are expected to grow.

BNPL RISK FACTORS

- ▶ **Consumer over-indebtedness:** BNPL is typically not reported to credit bureaus — consumers can accumulate debt across multiple BNPL providers simultaneously without lenders seeing the total picture. Studies show 40%+ of BNPL users have missed at least one payment.
- ▶ **Regulatory gap:** BNPL products historically operated outside traditional consumer credit regulations (since they were interest-free). Regulators in UK, Australia, and EU are now applying consumer credit rules to BNPL — affordability checks, clear disclosure of fees, right to complain to ombudsman.

- ▶ **BNPL provider profitability:** During high interest rate environments, BNPL providers borrow at high rates but lend at 0% (to consumers) — their net interest margin collapses. Klarna reported significant losses in 2022. Business model sustainability is questioned.
- ▶ **Merchant concentration risk:** Large retailers (Amazon, Target) can negotiate BNPL away, or create their own. Small and medium BNPL providers risk losing their distribution as big tech enters the space.

6. Cryptocurrency Payments

CRYPTOCURRENCY

A **cryptocurrency** is a digital or virtual currency that uses cryptography (specifically blockchain technology) to secure transactions, control the creation of additional units, and verify asset transfers.

Unlike traditional currencies, cryptocurrencies are decentralized — they operate without a central bank or government authority.

BITCOIN AS A PAYMENT METHOD

- ▶ **How Bitcoin payments work:** The merchant provides a Bitcoin wallet address (a long alphanumeric string) or a QR code encoding the address. The customer sends Bitcoin from their wallet to the merchant's address. The transaction is broadcast to the Bitcoin network and confirmed by miners (typically 6 confirmations required = ~60 minutes). For small purchases, some merchants accept 0-confirmation (immediate but technically reversible).
- ▶ **Price volatility problem:** Bitcoin's price can fluctuate 5–20% in a single day. A merchant who priced a product at 0.0001 BTC (worth \$4) in the morning may receive the equivalent of \$3.80 or \$4.30 by the time the transaction confirms. Most merchants using crypto convert immediately to fiat currency via a payment processor (Coinbase Commerce, BitPay) to eliminate this exposure.
- ▶ **Transaction fees and speed:** Bitcoin transaction fees vary with network congestion — can range from \$0.50 to \$50+ during peak periods. Confirmation time: 10 minutes per block, 60 minutes for secure confirmation. Too slow and expensive for everyday small purchases. Bitcoin Lightning Network (layer 2) addresses this — enables near-instant, near-free micropayments.
- ▶ **Irreversibility:** Confirmed crypto transactions cannot be reversed — no chargebacks. For merchants, this is an advantage (eliminates chargeback fraud, which costs e-commerce merchants billions annually). For consumers, there is no protection — a mistaken payment or a merchant scam cannot be reversed by any authority.

STABLECOINS

Stablecoins are cryptocurrencies pegged to a stable asset — typically the US Dollar. They solve the volatility problem while retaining the benefits of blockchain payments (fast, global, low-fee).

- ▶ **USDT (Tether):** Most widely traded stablecoin. Pegged 1:1 to USD. Widely used for cross-border B2B payments — a Bangladeshi importer can pay a Chinese supplier in USDT instantly, avoiding the delay and fees of traditional SWIFT wire transfers.
- ▶ **USDC (USD Coin):** Issued by Coinbase/Circle consortium. Fully audited USD reserves. Increasingly used in DeFi (Decentralized Finance) applications.
- ▶ **CBDC — Central Bank Digital Currency:** Government-issued digital currencies — the digital equivalent of banknotes. Bangladesh Bank is exploring a Digital Taka CBDC concept. China launched the Digital Yuan (e-CNY). CBDCs combine cryptocurrency technology with central bank backing and fiat currency stability.

OPPORTUNITIES AND RISKS OF CRYPTO IN E-COMMERCE

OPPORTUNITIES

- ▶ No chargebacks — eliminates chargeback fraud
- ▶ Global reach — no currency conversion barriers
- ▶ Lower fees than card networks for cross-border
- ▶ Access unbanked populations with mobile crypto wallets
- ▶ Appeals to privacy-conscious customers
- ▶ B2B cross-border settlements faster and cheaper

RISKS

- ▶ Price volatility (non-stablecoin crypto)
- ▶ Regulatory uncertainty — Bangladesh Bank restricts crypto transactions
- ▶ Low consumer adoption — limited mainstream use
- ▶ Irreversibility — no consumer protection
- ▶ Exchange and custody security risks (exchange hacks)
- ▶ Complex tax treatment — each transaction may be a taxable event

BANGLADESH LEGAL NOTE

Bangladesh Bank issued a circular in 2014 warning that trading, holding, or transacting in cryptocurrency is illegal under the Foreign Exchange Regulation Act and Money Laundering Prevention Act of Bangladesh. Violation can result in criminal prosecution. Despite this, peer-to-peer crypto trading exists. This regulatory position is evolving globally — students should note the *legal risk* of crypto payments for Bangladeshi e-commerce merchants.

7. Payment Security: PCI-DSS Standard

PCI-DSS is a set of security standards developed by the PCI Security Standards Council (founded jointly by Visa, Mastercard, American Express, Discover, and JCB in 2004) to ensure that all companies that accept, process, store, or transmit credit card information maintain a secure environment. Compliance is not optional — it is a contractual requirement for any business that accepts card payments.

THE 12 PCI-DSS REQUIREMENTS (ORGANIZED IN 6 GOALS)

Goal	Requirement #	Requirement Description
Build and maintain a secure network	1	Install and maintain a firewall configuration to protect cardholder data
	2	Do not use vendor-supplied defaults for system passwords and other security parameters
Protect cardholder data	3	Protect stored cardholder data — encrypt stored PAN; never store CVV after authorization
	4	Encrypt transmission of cardholder data across open, public networks (mandate TLS 1.2+)
Maintain a vulnerability management program	5	Protect all systems against malware and regularly update antivirus software
	6	Develop and maintain secure systems and applications — patch vulnerabilities promptly
Implement strong access control	7	Restrict access to cardholder data by business need-to-know (least privilege principle)
	8	Identify and authenticate access — unique user IDs, strong passwords, MFA for administrator access
9	Restrict physical access to cardholder data — lock server rooms, secure physical documents	
Regularly monitor and test networks	10	Track and monitor all access to network resources and cardholder data — audit logs

Goal	Requirement #	Requirement Description
	11	Regularly test security systems and processes — penetration testing, vulnerability scanning
Maintain an information security policy	12	Maintain a policy that addresses information security for all personnel

EXAM TIP

You do not need to memorize all 12 PCI-DSS requirements individually but should know: (1) what PCI-DSS is and who created it, (2) the 6 goals, (3) that it is a contractual requirement (not law), (4) the key principle — never store CVV, always encrypt card data in transit and at rest, use tokenization. A common exam question: "What is PCI-DSS? Why is it important for e-commerce businesses?" Also note: merchants who use a payment gateway like Stripe or SSL Commerz are protected by the gateway's PCI compliance — they never touch raw card data.

E-Commerce Security: Encryption & Protocols

CO4 Bloom's: Understand Teaching: Lecture + Diagram + Demo

Security is the technical foundation on which all e-commerce trust is built. Every time a customer enters their card number or password on a website, they are trusting that the underlying cryptographic systems will protect their data. This class provides a thorough understanding of how encryption works, the different types of encryption, hash functions, digital signatures, and the SSL/TLS protocol that protects all e-commerce communication.

1. Five Dimensions of E-Commerce Security

Security in e-commerce is multi-dimensional. Each dimension must be satisfied for a system to be considered secure. A failure in any one dimension creates a vulnerability.

Dimension	Definition	Question It Answers	Threat if Violated	Technical Solution
Confidentiality	Information is accessible only to those authorized to access it; unauthorized parties cannot read it	"Can only the intended recipient read this?"	Data interception, eavesdropping (man-in-the-middle), credential theft	Encryption (AES, RSA), TLS/HTTPS, access controls
Integrity	Information has not been altered or corrupted in transit or in storage without authorization	"Has this data been modified?"	Data tampering — altering order amounts, modifying payments in transit	Hash functions (SHA-256), digital signatures, checksums, HMAC
Availability	Systems and data are accessible to authorized users when needed	"Is the system accessible when I need it?"	DDoS attacks, ransomware, hardware failure, network outages	Redundancy, load balancing, DDoS mitigation, disaster recovery plans
Authenticity	The identity of both parties in a transaction is genuine — the person/system claiming an identity is who they say they are	"Am I really communicating with daraz.com.bd and not an impostor?"	Phishing websites (fake login pages), identity spoofing, session hijacking	Digital certificates, SSL/TLS (Certificate Authorities), multi-factor authentication

Dimension	Definition	Question It Answers	Threat if Violated	Technical Solution
Non-Repudiation	A party cannot deny having participated in a transaction — there is unforgeable proof that a specific party sent a specific message or made a specific transaction	"Can either party deny that this transaction happened?"	Order repudiation ("I never placed this order"), contract disputes, payment disputes	Digital signatures (cryptographically binding signer to the message), audit logs, timestamping

CIA TRIAD — THE CORE THREE

The foundational subset is the **CIA Triad: Confidentiality, Integrity, Availability**. This is the most-cited framework in information security. Authentication and Non-repudiation extend the CIA Triad specifically for transaction security. For exam purposes: always know the CIA Triad plus Authentication and Non-Repudiation as the five dimensions specific to e-commerce security.

2. Symmetric Encryption — AES

SYMMETRIC ENCRYPTION

Symmetric encryption (also called secret-key encryption or shared-key encryption) uses the same key for both encryption and decryption. The sender uses Key K to encrypt plaintext into ciphertext; the receiver uses the same Key K to decrypt the ciphertext back to plaintext. Both parties must possess the identical key — this is both its strength (speed) and weakness (key distribution problem).



Plaintext + Key K → Encryption Algorithm → Ciphertext

Sender: "Hello Rahim" + Key K → [7f2a9b3c...] (unreadable ciphertext)



Ciphertext travels over the network

Anyone who intercepts sees only [7f2a9b3c...] — meaningless without Key K



Ciphertext + Key K → Decryption Algorithm → Plaintext

Receiver: [7f2a9b3c...] + Key K → "Hello Rahim" (original message restored)

AES — ADVANCED ENCRYPTION STANDARD

AES (Advanced Encryption Standard) is the global standard for symmetric encryption, adopted by NIST (National Institute of Standards and Technology) in 2001 after an international competition. It replaced the older DES (Data Encryption Standard, 56-bit — now computationally broken) and Triple-DES.

- ▶ **Key sizes:** AES supports three key lengths: **128-bit** (10 rounds), **192-bit** (12 rounds), and **256-bit** (14 rounds). AES-256 is considered "military grade" encryption and is practically unbreakable with current computational technology — a brute-force attack would take longer than the age of the universe.
- ▶ **Block cipher:** AES operates on fixed-size blocks of 128 bits (16 bytes). Data longer than 128 bits is divided into 128-bit blocks and each block is encrypted independently (ECB mode) or with a chain dependency on the previous block (CBC mode) or as a stream cipher (CTR, GCM modes).
- ▶ **Rounds and operations:** Each round involves four operations: SubBytes (byte-by-byte substitution using a lookup table called S-Box), ShiftRows (rotating rows of the state array), MixColumns (matrix multiplication for diffusion), AddRoundKey (XOR with round key derived from the master key). These four operations combined ensure both confusion (hiding relationship between plaintext and ciphertext) and diffusion (spreading influence of each plaintext bit across the ciphertext).
- ▶ **Speed:** Symmetric encryption is extremely fast — modern CPUs have hardware-level AES acceleration (AES-NI instructions). AES can encrypt gigabytes per second, making it suitable for bulk data encryption.
- ▶ **Use in e-commerce:** AES-256 encrypts stored data (credit card databases, customer PII, passwords — though passwords use hashing, not encryption), HTTPS session data (AES is used as the bulk encryption cipher within TLS after the asymmetric handshake), encrypted storage (full-disk encryption on servers), and API payload encryption.
- ▶ **The key distribution problem:** For two parties who have never communicated before to use symmetric encryption, they must first securely exchange the secret key. Doing this over an insecure internet connection is the fundamental problem symmetric encryption cannot solve on its own — this is what asymmetric encryption (RSA) solves.

3. Asymmetric Encryption — RSA

ASYMMETRIC ENCRYPTION (PUBLIC-KEY CRYPTOGRAPHY)

Asymmetric encryption uses a mathematically related pair of keys — a public key and a private key. What one key encrypts, only the other key can decrypt. The public key is freely distributed to anyone; the private key is kept absolutely secret by its owner. The two keys are generated together as a mathematically inseparable pair but it is computationally infeasible to derive the private key from the public key.

RSA — RIVEST-SHAMIR-ADLEMAN

RSA (named after inventors Ron Rivest, Adi Shamir, and Leonard Adleman, 1977) is the most widely deployed asymmetric encryption algorithm. Its security is based on the practical difficulty of factoring the product of two very large prime numbers — a problem that is easy to compute in one direction but computationally intractable to reverse.

RSA Conceptual Formula:

Encryption: $C = M^e \bmod n$

// C = ciphertext, M = plaintext message (as integer), e = public exponent, n = modulus

Decryption: $M = C^d \bmod n$

// d = private exponent (kept secret); same n (public modulus)

Key Generation: $n = p \times q$

// n is the product of two large prime numbers p and q (kept secret)

// Security: given n , finding p and q (factoring) is computationally infeasible for large n

RSA key sizes: 2048-bit (minimum recommended), 4096-bit (high security)

ENCRYPTION FOR CONFIDENTIALITY — "ENCRYPT WITH RECIPIENT'S PUBLIC KEY"



Sender encrypts with RECEIVER's public key

Alice wants to send a secret message to Rahim. Alice uses Rahim's public key (freely available) to encrypt: $C = M^e_{\text{rahim}} \bmod n_{\text{rahim}}$. Only Rahim's private key can decrypt this.



Encrypted ciphertext C travels over the network

Even if intercepted, C is useless without Rahim's private key



Receiver decrypts with their OWN private key

Rahim uses his private key: $M = C^d_{\text{rahim}} \bmod n_{\text{rahim}}$. Plaintext message is recovered. Even Alice cannot decrypt it without Rahim's private key.

WHY RSA IS SLOWER THAN AES

RSA involves modular exponentiation of very large numbers (2048-bit) — computationally expensive. RSA is approximately 1000x slower than AES for bulk data. Therefore, in practice, RSA is never used to encrypt large amounts of data directly.

HYBRID CRYPTOGRAPHY — HOW TLS COMBINES RSA AND AES

The standard solution is **hybrid encryption**: (1) Use RSA (or Diffie-Hellman) to securely exchange a random symmetric session key (small data — 128 or 256 bits). (2) Use that session key with AES to

encrypt all actual data (fast, efficient). This gives you the key distribution security of asymmetric encryption and the speed of symmetric encryption. This is exactly how TLS/HTTPS works.

4. Hash Functions: SHA-256 and MD5

CRYPTOGRAPHIC HASH FUNCTION

A **cryptographic hash function** takes an input of any size and produces a fixed-size output called a **hash**, **digest**, or **fingerprint**. Hash functions are one-way — given the hash, it is computationally infeasible to recover the original input (pre-image resistance). Any change in the input, no matter how small, produces a completely different hash (avalanche effect).

KEY PROPERTIES OF CRYPTOGRAPHIC HASH FUNCTIONS

- ▶ **Deterministic:** The same input always produces the same hash. "Hello" always hashes to the same value.
- ▶ **One-way (Pre-image resistance):** Given hash H, it is computationally infeasible to find any input M such that $\text{Hash}(M) = H$. You cannot reverse a hash to get the original data. This is why passwords are stored as hashes, not in plaintext.
- ▶ **Avalanche effect (Sensitivity):** Changing even one bit of the input produces a completely different hash output. "Hello" and "Hello!" produce totally different hashes — there is no partial similarity.
- ▶ **Collision resistance:** It is computationally infeasible to find two different inputs M1 and M2 such that $\text{Hash}(M1) = \text{Hash}(M2)$. A collision means two different files have the same hash — catastrophic for security. MD5 is broken (collisions found). SHA-1 is deprecated. SHA-256 is currently secure.
- ▶ **Fixed output size:** SHA-256 always produces a 256-bit (32-byte, 64 hex-character) hash regardless of whether the input is 1 byte or 1 terabyte.

SHA-256 Example:

Input: "Hello World"

SHA-256 Hash:

a591a6d40bf420404a011733cfb7b190d62c65bf0bcda32b57b277d9ad9f146e

Input: "Hello World!" (added one character)

SHA-256 Hash:

7f83b1657ff1fc53b92dc18148a1d65dfc2d4b1fa3d677284add200126d9069

// Completely different hash despite near-identical input – avalanche effect

MD5 VS. SHA-256

Feature	MD5 (Message Digest 5)	SHA-256 (Secure Hash Algorithm 256)
Developed by	Ron Rivest, 1992	NSA, NIST, 2001 (SHA-2 family)
Output size	128-bit hash (32 hex characters)	256-bit hash (64 hex characters)
Speed	Faster	Slightly slower but hardware-accelerated
Security status	Broken — practical collision attacks demonstrated (1996, 2004). Do NOT use for security-critical applications.	Secure — no known practical attacks as of 2024. Recommended standard.
Current use	File checksums for non-security verification (checking download integrity against known MD5 provided by the source), legacy systems	Password hashing (with bcrypt/scrypt), digital signatures, TLS certificate fingerprints, blockchain (Bitcoin uses SHA-256), code signing, HMAC

APPLICATIONS OF HASH FUNCTIONS IN E-COMMERCE

- ▶ **Password storage:** NEVER store passwords in plaintext (if the database is breached, all passwords are exposed). Store Hash(password + salt). When a user logs in, hash their input and compare with stored hash. "Salt" is a random value added to prevent rainbow table attacks (precomputed hash databases). Modern password hashing uses bcrypt, scrypt, or Argon2 — deliberately slow algorithms that resist brute-force attacks.
- ▶ **Data integrity verification:** When a software download is provided, the publisher also provides its SHA-256 hash. After download, users recompute the hash and compare — any tampering or corruption changes the hash, immediately detected.
- ▶ **Digital signatures:** Rather than signing the entire document (slow with RSA), sign the hash of the document. Verify by: (1) decrypting the signature with the signer's public key to get the hash, (2) independently computing the hash of the received document, (3) comparing the two hashes. If they match, the document was signed by the claimed signer and has not been modified.
- ▶ **Blockchain:** Bitcoin and Ethereum use SHA-256 and Keccak-256 (SHA-3 variant) respectively. Each block's hash includes the previous block's hash, creating a chain — modifying any past block changes its hash, which changes all subsequent blocks' hashes, which invalidates the entire chain. This makes blockchain tamper-evident.
- ▶ **HMAC (Hash-based Message Authentication Code):** Combines a hash function with a secret key to produce a message authentication code. Used to verify both integrity and authenticity simultaneously. Used in API authentication — the API client computes HMAC(request_body + secret_key) and includes it as a header; the server recomputes and verifies.

5. Digital Signatures

DIGITAL SIGNATURE

A digital signature is a mathematical scheme for verifying the authenticity and integrity of a digital message or document. It provides the digital equivalent of a handwritten signature or a sealed envelope, but far more difficult to forge. A digital signature simultaneously proves: (1) the message was created by the claimed sender (authentication), (2) the message was not altered in transit (integrity), and (3) the sender cannot deny having sent it (non-repudiation).

HOW DIGITAL SIGNATURES WORK — STEP BY STEP

1 Sender Computes Hash of Message

Alice wants to sign a digital contract. She computes $\text{SHA-256}(\text{contract_document}) = \text{hash_value}$. This hash uniquely represents the exact content of the document.

2 Sender Signs the Hash with Their Private Key

Alice encrypts the hash using her own private key: $\text{Signature} = \text{hash_value}^d_{\text{alice}} \bmod n_{\text{alice}}$. This signature is unique to Alice (only she has her private key) and unique to this document (it is derived from this document's hash). The signature is attached to the document.

3 Document + Signature Transmitted

Alice sends the contract document and the attached digital signature to the recipient (Rahim) or to a public repository.

4 Receiver Decrypts Signature with Sender's Public Key

Rahim obtains Alice's public key (from a Certificate Authority or public key directory). He decrypts the signature: $\text{hash_from_signature} = \text{Signature}^e_{\text{alice}} \bmod n_{\text{alice}}$. This reveals the hash that Alice computed over the document.

5 Receiver Independently Computes Hash of Received Document

Rahim independently computes $\text{SHA-256}(\text{received_document}) = \text{hash_from_document}$.

6 Compare the Two Hashes

If $\text{hash_from_signature} == \text{hash_from_document}$: VALID — the document was signed by Alice and has not been modified. If they differ: INVALID — either the document was altered or the signature is forged. This comparison provides integrity + authenticity + non-repudiation simultaneously.

This is the exact opposite of encryption for confidentiality: Encryption uses the *receiver's* public key (anyone can send a secret to a specific person). Digital signatures use the *sender's* private key (only one specific person can sign, but anyone can verify). The rule: **Encrypt with PUBLIC key; Decrypt with PRIVATE key. Sign with PRIVATE key; Verify with PUBLIC key.**

6. SSL/TLS Handshake and HTTPS

TLS — TRANSPORT LAYER SECURITY

TLS (Transport Layer Security) is the cryptographic protocol that provides end-to-end security for communications over a network. It is the successor to SSL (Secure Sockets Layer — now deprecated and vulnerable). When you see "https://" and the padlock icon in your browser, TLS is protecting that connection. TLS provides: (1) Server authentication (proving the website is genuine), (2) Optionally client authentication, (3) Confidentiality (encrypting all data), (4) Integrity (detecting any tampering).

TLS 1.3 HANDSHAKE — STEP BY STEP

1 Client Hello

Browser sends a "Client Hello" message to the server containing: (a) TLS version supported (TLS 1.3); (b) list of supported cipher suites (combinations of key exchange, bulk encryption, and MAC algorithms — e.g., TLS_AES_256_GCM_SHA384); (c) client random — a randomly generated 32-byte number; (d) session ID (for resuming previous sessions); (e) supported extensions.

2 Server Hello + Certificate

Server responds with: (a) Selected TLS version and cipher suite; (b) server random — another 32-byte random number; (c) Server's **digital certificate** (X.509 format) — contains server's public key, domain name, issuing CA, validity period, and CA's digital signature. The certificate proves: "I am genuinely daraz.com.bd, and a trusted CA vouches for this."

3 Certificate Verification by Client

Browser verifies the certificate: (a) Is the certificate signed by a trusted Certificate Authority? The browser has a pre-installed list of ~150 trusted root CAs (DigiCert, Let's Encrypt, Comodo, GlobalSign). (b) Is the certificate for the correct domain name? (c) Is it within its validity period (not expired)? (d) Has the certificate been revoked (checks CRL/OCSP)? If all checks pass, the browser trusts the server's public key.

4 Key Exchange (Diffie-Hellman in TLS 1.3)

TLS 1.3 uses Ephemeral Diffie-Hellman (ECDHE) for key exchange. Both client and server independently generate a session key derived from: client random + server random + the Diffie-Hellman shared secret. The session key is never transmitted over the network — both sides derive the same key independently. This

provides **Perfect Forward Secrecy (PFS)** — even if the server's private key is later compromised, past sessions cannot be decrypted.

5 **Finished Messages — Handshake Verification**

Both client and server send "Finished" messages that are encrypted with the newly derived session key. If either side can decrypt the other's "Finished" message correctly, the handshake is verified — both parties have derived the same session key successfully. The TLS tunnel is now established.

6 **Encrypted Data Exchange**

All subsequent communication is encrypted with AES-GCM using the session key. HTTP requests and responses (product pages, form submissions, card data entry) travel inside this encrypted tunnel. Neither the ISP, the network provider, nor any eavesdropper between the client and server can read or modify the content.

CERTIFICATE AUTHORITIES (CAS) AND THE CHAIN OF TRUST

A **Certificate Authority (CA)** is a trusted third-party organization that issues digital certificates after verifying the identity of the certificate applicant. CAs form a hierarchical "chain of trust":

- ▶ **Root CAs:** The ultimate trust anchors — their certificates are pre-installed in all operating systems and browsers. Examples: DigiCert, Sectigo, Let's Encrypt, GlobalSign. Root CA private keys are kept in hardware security modules (HSMs) in physically secured vaults and are rarely used.
- ▶ **Intermediate CAs:** Certified by Root CAs; issue end-entity certificates to websites. This intermediate layer insulates the Root CA from daily operations.
- ▶ **End-Entity Certificates:** Issued to websites (domain-validated DV, organization-validated OV, or extended validation EV). The browser verifies the chain: website certificate → signed by Intermediate CA → signed by Root CA → trusted by browser.
- ▶ **Let's Encrypt:** A free, automated CA that has dramatically expanded HTTPS adoption — 300M+ websites use Let's Encrypt certificates. Critical for enabling small Bangladeshi e-commerce merchants to implement HTTPS at zero cost.
- ▶ **Certificate revocation:** If a certificate's private key is compromised, the CA publishes it on a Certificate Revocation List (CRL) or via Online Certificate Status Protocol (OCSP). Browsers check revocation status before trusting a certificate.

EXAM TIP — MOST COMMONLY TESTED SECURITY CONCEPTS

The most frequently examined topics in this class are: (1) The five security dimensions — know definitions and examples of threats for each; (2) Symmetric vs. Asymmetric encryption — know the key difference (same key vs. key pair), AES formula concept, RSA formula $C = M^e \bmod n$, and the key distribution problem; (3) Hash functions — one-way property, SHA-256 vs. MD5, use in passwords and integrity; (4)

Digital signatures — the rule "sign with private key, verify with public key" and the 6-step process; (5)
SSL/TLS — what the padlock means, what the handshake achieves, role of CAs. The formula $C = M^e \bmod n$ (RSA encryption) appears almost every exam.

Technical security protects systems from external attack, but the threats to e-commerce extend beyond code vulnerabilities. This class covers the human-centered threats (social engineering), the ethical responsibilities of e-commerce companies toward users, and the legal frameworks that govern digital commerce — internationally and specifically in Bangladesh.

1. Common E-Commerce Security Threats

SOCIAL ENGINEERING

Phishing

A fraudulent attempt to obtain sensitive information (passwords, card numbers, OTPs) by disguising as a trustworthy entity in digital communication.

Attackers send emails that appear to come from legitimate organizations (Daraz, bKash, Dutch-Bangla Bank) containing urgent messages ("Your account has been suspended — click here to verify"). The link leads to a fake website that looks identical to the real one but captures login credentials. Phishing is responsible for 80%+ of all security breaches globally.

MALICIOUS SOFTWARE

Malware

Software designed to disrupt, damage, or gain unauthorized access to computer systems. Malware taxonomy for e-commerce: (a) Keyloggers — record every keystroke, capturing passwords and card numbers typed by victims; (b) Banking Trojans — specifically target financial site credentials (Zeus, TrickBot); (c) Formjacking / web skimmers — malicious JavaScript injected into checkout pages to steal card data as it is entered (Magecart attacks — affected British Airways, Ticketmaster). The malware sends data to attackers' servers in real time.

INJECTION ATTACK

SQL Injection (SQLi)

An attacker inserts (injects) malicious SQL code into an input field that is passed unsanitized to a database query. If the web application doesn't validate input properly: a search box that accepts ' OR '1'='1 might return all records in the database instead of filtered results. SQLi can: extract the entire customer database (names, emails, hashed passwords, addresses), modify or delete database records, bypass authentication (logging in without valid credentials). Prevention: parameterized queries (prepared statements), input validation and sanitization, least-privilege database accounts.

CROSS-SITE ATTACK

Cross-Site Request Forgery (CSRF)

An attack that tricks an authenticated user's browser into making an unauthorized request to a web application where the user is currently logged in. Example: a user is logged in to their bank. They visit a malicious website that contains a hidden image tag: ``. The browser automatically sends this request to the bank with the user's valid session cookie. The bank processes it as a legitimate request. Prevention: CSRF tokens (random, unique tokens in forms that the server validates — an attacker's malicious page cannot know the user's CSRF token).

CROSS-SITE ATTACK

Cross-Site Scripting (XSS)

An attacker injects malicious JavaScript into a web page that is then served to and executed by other users' browsers. Types: Stored XSS (malicious script saved to the database — e.g., in a product review — and served to every viewer); Reflected XSS (malicious script in a URL parameter, executed when the victim clicks a crafted link). XSS can: steal session cookies (session hijacking), redirect users to phishing sites, modify page content to display fake prices or promotions, capture keystrokes. Prevention: output encoding (HTML-escaping user-generated content), Content Security Policy (CSP) headers.

AVAILABILITY ATTACK

DDoS Attack

Distributed Denial of Service — attackers direct a botnet (a network of thousands of compromised computers, or IoT devices) to flood a target website with massive volumes of requests, exhausting its bandwidth, server resources, or connection capacity. The site becomes unavailable to legitimate users. DDoS attacks on e-commerce sites cost tens of thousands of dollars per hour in lost sales. Mitigation: CDN with DDoS protection (Cloudflare, Akamai), traffic scrubbing, IP reputation filtering, rate limiting, anycast diffusion.

2. Social Engineering Attacks

SOCIAL ENGINEERING

Social engineering is the psychological manipulation of people into performing actions or divulging confidential information. It exploits human psychology — trust, authority, urgency, fear, curiosity — rather than technical vulnerabilities. The most sophisticated technical security can be bypassed if an employee can be tricked. Kevin Mitnick (famous hacker) famously said: "The human is the weakest link in security."

TYPES OF SOCIAL ENGINEERING

- ▶ **Phishing (covered above):** Mass email-based social engineering. Low specificity — same email sent to millions, designed to catch a small percentage of recipients.
- ▶ **Spear Phishing:** Highly targeted phishing — the attacker researches the specific victim (LinkedIn profile, company website, social media) and crafts a personalized, convincing message. "Hi Rahim, following up on the payment we discussed in yesterday's Zoom call..." Spear phishing success rate is dramatically higher than generic phishing. Business Email Compromise (BEC) — a type of spear phishing targeting financial staff — costs businesses \$27 billion annually.
- ▶ **Vishing (Voice Phishing):** Phone-call based social engineering. Attacker calls posing as bank security team, IT support, tax authority, or delivery company. Creates urgency ("Your account has suspicious activity — I need to verify your OTP immediately"). In Bangladesh, vishing scams often impersonate bKash customer service asking for PINs or OTPs.

- ▶ **Smishing (SMS Phishing):** SMS-based social engineering. "Your parcel is on hold. Click here to reschedule delivery: [malicious link]." Or fake prize-winning SMS requiring personal details. Extremely common in Bangladesh — "Congratulations! You have won 50,000 BDT in our lottery. Share your NID and bKash number to claim."
- ▶ **Pretexting:** Creating a fabricated scenario (pretext) to extract information. An attacker calls a company's IT helpdesk posing as a new employee: "Hi, I'm Karim from the Chittagong office, I can't access the system — can you reset my password?" The helpdesk, wanting to be helpful, may comply without proper verification. Defense: strict identity verification procedures, callback verification to known numbers.
- ▶ **Baiting:** Leaving a malware-infected USB drive in a visible location (company parking lot, bathroom). A curious employee plugs it in — the USB auto-executes malware. Exploits human curiosity. In digital form: "Download this free movie/software" links that contain malware.
- ▶ **Tailgating / Piggybacking:** Physical social engineering — following an authorized person through a secured door before it closes, gaining physical access to server rooms or offices without authorization.

DEFENSES AGAINST SOCIAL ENGINEERING

Security awareness training (regular, simulated phishing tests), strict procedures for out-of-band verification (call back on official number before acting on unusual requests), multi-factor authentication (so a stolen password alone is insufficient), zero-trust security model (verify every access request regardless of source), clear escalation procedures for suspicious contact.

3. Ethical Issues in E-Commerce

3A. PRICE DISCRIMINATION

Digital price discrimination is the practice of charging different customers different prices for the same product based on their inferred willingness to pay — often without their knowledge.

- ▶ **First-degree (perfect) price discrimination:** Each customer is charged their maximum willingness to pay. Possible with granular data — behavioral history, income proxies (device type, location, browsing patterns). Airlines already practice this extensively through yield management systems.
- ▶ **Third-degree price discrimination:** Different prices for different customer segments — students, senior citizens, loyalty members. Less controversial when the segmentation criterion is transparent.
- ▶ **Dynamic pricing in e-commerce:** Prices change in real time based on demand, competitor prices, inventory, and time. Amazon changes prices 2.5 million times per day. Largely accepted for commodity products but raises ethical concerns when applied to necessities during emergencies (price gouging).
- ▶ **Opaque price discrimination:** When users are shown different prices on the same platform based on their device (iOS users see higher prices than Android users — studied on several hotel booking platforms),

location, or past behavior — without disclosure. This is ethically problematic and in some jurisdictions illegal (e.g., the EU's Platform-to-Business regulation requires transparency).

3B. DARK PATTERNS

DARK PATTERNS

Dark patterns are user interface design choices that trick or manipulate users into doing things they did not intend — often benefiting the company at the user's expense. The term was coined by UX designer Harry Brignull in 2010. Dark patterns exploit cognitive biases and visual deception.

- ▶ **Confirmshaming:** Opt-out language designed to make declining feel bad. "No thanks, I don't want to save money." Guilts users into subscribing.
- ▶ **Hidden costs (Drip pricing):** Advertised price is low; service fees, delivery fees, and taxes are only revealed at the final checkout step. Hotels and airlines are notorious for this. Airbnb's "cleaning fees" revealed late in booking is a form of drip pricing.
- ▶ **Roach motels:** Easy to sign up, extremely difficult to cancel. Subscription services that require calling a specific phone number during business hours to cancel. Amazon Prime in some regions was investigated for this.
- ▶ **Misdirection:** Visual design draws attention to one option while obscuring the alternative. The "Accept all cookies" button is large and green; the "Manage preferences" link is small, grey, and in a corner.
- ▶ **Trick questions:** Confusing opt-in/opt-out language with double negatives. "Uncheck this box if you do not want to not receive marketing emails." Impossible to parse correctly under time pressure.
- ▶ **Forced continuity:** Free trial automatically converts to paid subscription without clear notification. Credit card charged the day after trial ends.
- ▶ **Privacy Zuckering (named after Facebook's Mark Zuckerberg):** Confusing privacy settings that default to maximum data sharing, with changes requiring multiple clicks through non-intuitive menus.

REGULATORY RESPONSE TO DARK PATTERNS

The EU's Digital Services Act (DSA, 2022) explicitly prohibits dark patterns for large online platforms. The US FTC has issued enforcement actions against dark patterns in subscription cancellation flows. India's Consumer Protection (E-Commerce) Rules 2020 prohibit misleading interfaces. Bangladesh lacks specific dark pattern legislation currently, but the Consumer Rights Protection Act 2009 provides general consumer protection that could apply.

3C. DATA HARVESTING AND SURVEILLANCE CAPITALISM

- ▶ **Scope of data collection:** Every click, scroll, dwell time, search query, purchase, location (if permitted), device identifier, and demographic inference is collected by major e-commerce platforms. Amazon knows not just what you bought but what you considered buying, compared, and rejected. This behavioral data is extraordinarily valuable for targeting and prediction.
- ▶ **Third-party tracking:** Websites embed tracking pixels and JavaScript from dozens of third-party advertising networks (Google Ads, Facebook Pixel, Criteo). These trackers follow users across the entire internet, building detailed profiles that span websites. A user's visit to a health information site, a legal services site, and a financial products site all feed into the same profile.
- ▶ **Surveillance capitalism (Shoshana Zuboff):** A term coined by academic Shoshana Zuboff describing an economic system based on the commodification of personal data for profit. The core dynamic: behavioral data is "surplus" extracted from users' digital activities, refined by AI into "prediction products" sold to advertisers. Users are not the customers — they are the raw material whose behavior is being sold.
- ▶ **Inferred sensitive data:** From innocent browsing patterns, platforms can infer sensitive attributes: pregnancy (from shopping patterns — Target's famous case), political affiliation, sexual orientation, mental health status, financial distress. These inferences are made without explicit disclosure and used for targeting without consent.

4. Privacy Laws and Regulations

GDPR — GENERAL DATA PROTECTION REGULATION (EU, 2018)

GDPR — KEY PROVISIONS FOR E-COMMERCE

The GDPR is the world's most comprehensive data protection law, applying to any organization that processes personal data of EU residents — regardless of where the organization is based. A Bangladeshi company with EU customers must comply with GDPR.

- ▶ **Lawful basis for processing:** Data can only be collected and processed with a legal basis: (a) explicit consent, (b) performance of a contract, (c) legal obligation, (d) vital interests, (e) public task, or (f) legitimate interests (narrowly interpreted). Consent must be freely given, specific, informed, and unambiguous — pre-checked boxes are NOT valid consent under GDPR.
- ▶ **Right to be forgotten (erasure):** Individuals can request that their personal data be deleted — and organizations must comply unless there is an overriding legal basis for retention (e.g., accounting records). E-commerce companies must be able to delete all customer data upon request.
- ▶ **Right of access:** Individuals can request a complete copy of all personal data an organization holds about them (Subject Access Request — SAR). Organizations have 30 days to comply.

- ▶ **Data portability:** Individuals can request their data in a machine-readable format and transfer it to a different service provider.
- ▶ **Privacy by design:** Privacy considerations must be built into systems from the start — not added as an afterthought. Data minimization principle — only collect data that is strictly necessary for the stated purpose.
- ▶ **Data breach notification:** Organizations must report breaches to their supervisory authority within 72 hours and to affected individuals without undue delay when the breach is likely to result in high risk to individuals.
- ▶ **Data Protection Officer (DPO):** Large-scale data processors must appoint a DPO responsible for ensuring GDPR compliance.
- ▶ **Fines:** Up to €20 million or 4% of global annual turnover (whichever is higher) for serious violations. Meta (Facebook) was fined €1.2 billion in 2023 — the largest GDPR fine to date for illegal transfer of EU user data to US servers.

CCPA — CALIFORNIA CONSUMER PRIVACY ACT (USA, 2020)

- ▶ **Right to know:** California residents can request what personal information businesses have collected about them, from whom it was collected, and to whom it is disclosed.
- ▶ **Right to delete:** Request deletion of personal information (with exceptions for transaction completion, legal obligations, etc.).
- ▶ **Right to opt-out of sale:** The right to direct businesses to not sell their personal information. Businesses must provide a "Do Not Sell My Personal Information" link on their homepage.
- ▶ **Non-discrimination:** Businesses cannot discriminate against consumers for exercising CCPA rights (e.g., charging higher prices or providing lower quality service).
- ▶ **Applicability threshold:** Applies to for-profit businesses that (a) have annual revenue > \$25M, (b) buy/sell data of 100,000+ consumers, or (c) derive 50%+ revenue from selling consumer data. Does not apply to all businesses unlike GDPR.
- ▶ **CPRA (2023 amendment):** California Privacy Rights Act expanded CCPA — added right to correct data, added the category of "sensitive personal information," and created the California Privacy Protection Agency (CPPA) as a dedicated enforcement body.

Feature	GDPR (EU)	CCPA (California/USA)
Geographic scope	Any company processing EU residents' data worldwide	For-profit businesses meeting thresholds dealing with California residents

Feature	GDPR (EU)	CCPA (California/USA)
Approach	Opt-in: requires consent before most data processing	Opt-out: data can be collected by default; consumers must actively opt-out of sale
Maximum fine	€20M or 4% of global revenue	\$7,500 per intentional violation
Data breach notification	72 hours to supervisory authority; affected individuals without undue delay	Expedient notification to affected California residents
Children's data	Under 16 requires parental consent (member states can lower to 13)	COPPA (separate US law) covers under 13
Data portability	Yes — machine-readable format	Yes — specific categories

5. Intellectual Property in Digital Commerce

TRADEMARK

A **trademark** is a recognizable sign, design, or expression that identifies products or services of a particular source and distinguishes them from competitors. In e-commerce, trademark issues arise in:

- ▶ **Domain name squatting (Cybersquatting):** Registering domain names that are identical or confusingly similar to established trademarks, hoping to sell them to the trademark owner or divert their traffic. ICANN's UDRP (Uniform Domain-Name Dispute-Resolution Policy) provides a mechanism to reclaim such domains.
- ▶ **Keyword advertising (Adwords) abuse:** Competitors bidding on your brand name as a search keyword so their ads appear when users search for your brand. Legal in most jurisdictions (comparative advertising) but using the trademark in the ad text itself may infringe.
- ▶ **Counterfeit goods:** Selling fake branded products on marketplaces. A major problem for Amazon, Daraz — counterfeit luxury goods, electronics, and medicines listed by third-party sellers. Platforms are under increasing legal pressure to take responsibility for counterfeit goods sold through their marketplaces.
- ▶ **Metatag stuffing:** Embedding competitor trademark names in website metatags or hidden text so search engines associate the page with competitor searches. Now largely addressed by search engine algorithm changes but was a significant early-internet issue.

COPYRIGHT

Copyright automatically protects original works of authorship — text, images, music, software, video, databases — giving the creator exclusive rights to reproduce, distribute, and create derivative works.

- ▶ **Product image copyright:** Manufacturers' product photos are copyrighted. Retailers need a license to use them. Resellers on marketplaces sometimes use unauthorized product images — technically infringement even if the underlying product sale is legitimate.
- ▶ **User-generated content (UGC) ownership:** When customers post reviews or photos on a platform, the platform's terms of service typically grant broad licenses to use that content. The ethics of exploiting UGC commercially without significant compensation is increasingly debated.
- ▶ **Software licensing:** E-commerce platforms and tools are protected by copyright and licensed (open source, proprietary, SaaS). Using unlicensed software exposes businesses to significant liability.
- ▶ **Digital piracy:** Unauthorized distribution of copyrighted music, movies, books, or software via digital channels. Platforms hosting infringing content may be liable under secondary infringement doctrines unless they qualify for safe harbor (DMCA Section 512 in the USA requires timely takedown of reported infringing content).
- ▶ **Bangladesh Copyright Act 2000:** Provides protection to literary, artistic, musical, and software works. Limited enforcement capacity has historically made digital copyright enforcement weak in Bangladesh, but this is improving.

6. Consumer Protection in E-Commerce

- ▶ **Right of withdrawal (cooling-off period):** Under EU consumer law (Consumer Rights Directive), online buyers have 14 days to return goods purchased online for any reason, without giving justification, at no cost. This "right of withdrawal" recognizes that online buyers cannot physically inspect goods before purchase. Bangladesh's Consumer Rights Protection Act 2009 provides some protections but not as comprehensive a cooling-off right.
- ▶ **Counterfeit goods:** Selling counterfeit products (fake Nike shoes, fake Apple chargers, fake medications) harms consumers financially, damages legitimate brand owners, and in the case of fake medicines, poses life safety risks. Platforms are legally required to take down reported counterfeit listings and increasingly face liability for facilitating counterfeit sales.
- ▶ **Chargebacks:** A consumer's mechanism to dispute a card transaction — requesting the bank to reverse a payment. Legitimate reasons: item not received, item significantly not as described, unauthorized transaction. Chargeback fraud ("friendly fraud") is when consumers falsely claim they did not receive or authorize a purchase to get goods for free. Chargeback rates above 1% of transactions trigger fines and potentially merchant account termination by card networks.
- ▶ **Misleading advertising and fake reviews:** Fake product reviews (bought reviews, competitor review bombing) distort the information environment consumers rely on for purchase decisions. Amazon deletes millions of fake reviews monthly. FTC in the USA requires disclosure when reviews are incentivized. Bangladesh's consumer protection legislation covers misleading advertising.

- ▶ **Accessibility:** E-commerce websites have ethical (and increasingly legal) obligations to be accessible to persons with disabilities — screen-reader compatible markup (ARIA labels), sufficient color contrast, keyboard navigation. WCAG (Web Content Accessibility Guidelines) 2.1 Level AA is the international standard. EU Web Accessibility Directive mandates compliance for public sector websites.

7. Bangladesh Legal Framework for E-Commerce

DIGITAL SECURITY ACT 2018 (DSA)

DIGITAL SECURITY ACT 2018

Bangladesh's primary cybersecurity legislation, enacted to address cybercrimes and digital security threats. The DSA replaced sections 54, 55, 56, 57, and 66 of the ICT Act 2006 with expanded provisions.

- ▶ **Cybercrime offenses covered:** Unauthorized access to computer systems (hacking), distribution of malicious programs/malware, identity theft, electronic forgery, digital fraud, publishing obscene content, defamation via digital media, cyberterrorism.
- ▶ **Section 17 — Attacking Critical Information Infrastructure:** Attacks on government, banking, financial, healthcare, or utilities digital infrastructure. Maximum sentence: 14 years imprisonment and fine.
- ▶ **Section 19 — Unauthorized Access:** Accessing or attempting to access any computer, network, or data system without authorization. Sentence: up to 7 years imprisonment.
- ▶ **Section 25 — Offensive, false, or threatening content:** Publishing, broadcasting, or distributing information through websites or digital media that is offensive, threatening, or causes deterioration of law and order. Sentence: up to 3 years, expandable to 5 years.
- ▶ **Section 29 — Defamation through digital media:** Publishing defamatory information online. Sentence: 3 years and fine. This provision has been criticized by press freedom organizations as potentially suppressing legitimate journalism — a controversial aspect of the DSA. The government replaced DSA with the Cyber Security Act 2023, amending some provisions.
- ▶ **Section 32 — Accessing government computer systems:** Special protection for government digital infrastructure with enhanced penalties.
- ▶ **E-commerce relevance:** E-commerce businesses must ensure their platforms do not host content that could trigger DSA provisions, protect their systems against unauthorized access, and ensure employee conduct online does not expose the company to liability.

ICT ACT 2006 — RELEVANT PROVISIONS

- ▶ **Legal recognition of electronic documents and signatures:** The ICT Act recognizes electronic records and digital signatures as legally valid — foundational for e-contracts and digital commerce.
- ▶ **Electronic contracts:** Contracts formed through electronic communication (email, website click-wrap agreements) have legal validity under the ICT Act, bringing Bangladesh in line with UNCITRAL Model Law on E-Commerce.
- ▶ **Certifying authorities:** The ICT Act establishes a framework for licensing Digital Signature Certificate issuing authorities — the Bangladesh digital PKI infrastructure.
- ▶ **Controller of Certifying Authorities (CCA):** Government body overseeing digital signature infrastructure in Bangladesh.

NATIONAL DIGITAL COMMERCE POLICY 2018

- ▶ Provides a policy framework for the development of e-commerce in Bangladesh — consumer protection standards, platform responsibilities, dispute resolution mechanisms, logistics standards.
- ▶ Mandates that online marketplace platforms must verify seller identities and hold them accountable for product quality.
- ▶ Addresses mobile financial services (MFS) integration with e-commerce platforms.
- ▶ Sets standards for product return and refund policies.
- ▶ Preceded the specific challenges that emerged with COVID-19-era e-commerce boom — subsequent guidelines were issued in 2020–2021 addressing advance payment collection abuse (incidents where businesses collected crores in advance payments without delivering).

CONSUMER RIGHTS PROTECTION ACT 2009

- ▶ Establishes Directorate of National Consumer Rights Protection (DNCRP) as the enforcement body.
- ▶ Prohibits: selling adulterated goods, false advertising, price gouging, selling goods below standard quality.
- ▶ Complaints can be filed with DNCRP against e-commerce businesses that fail to deliver, deliver wrong items, or engage in misleading advertising.
- ▶ E-commerce explosion during COVID-19 led to a surge in consumer complaints — advance payment fraud (customers paid; products never delivered) was a particular problem leading to regulatory tightening of e-commerce advance payment practices.

8. Summary: Key Concepts for Exam Review

Topic	Key Concept	Exam-Ready Answer
Phishing	Fraudulent emails/websites impersonating trusted entities to steal credentials	Attacker sends fake bKash email → victim enters PIN on fake site → attacker steals funds
SQL Injection	Malicious SQL code in input fields to manipulate database queries	Input ' OR '1'='1 → bypasses authentication; Prevention: parameterized queries
XSS	Injecting malicious JavaScript into web pages served to other users	Stored XSS in product review → every viewer's session cookie stolen
CSRF	Tricking authenticated user's browser into unauthorized actions	Hidden img tag on malicious site triggers logged-in bank transfer; Prevention: CSRF tokens
Spear Phishing	Targeted phishing using personal details for higher success rate	BEC attacks; personalized emails from "CEO" to finance team requesting wire transfers
Pretexting	Fabricated scenario used to extract information	Fake IT support call requesting password reset without proper verification
Price Discrimination	Different prices to different customers based on willingness to pay	iOS users shown higher hotel prices than Android users; dynamic pricing based on browsing history
Dark Patterns	UI design tricks that manipulate users against their interests	Hidden fees revealed at checkout; difficult cancellation flows; confirmshaming
GDPR	EU data protection law requiring consent, rights of access/erasure, 72-hr breach notification	Opt-in consent; right to deletion; €20M or 4% global revenue fine
CCPA	California privacy law with opt-out rights and data disclosure requirements	Right to know, delete, opt-out of sale; applies to large businesses only
DSA 2018	Bangladesh's primary cybercrime law covering hacking, malware, defamation, cyberterrorism	Section 17 (critical infrastructure attacks: 14 years); Section 19 (unauthorized access: 7 years)
ICT Act 2006	Legal recognition of electronic documents, signatures, and contracts in Bangladesh	E-contracts are legally valid; framework for digital signatures
Trademark in e-commerce	Cybersquatting, keyword bidding, counterfeit goods are key trademark issues	ICANN UDRP for domain disputes; platforms required to remove counterfeit listings

Topic	Key Concept	Exam-Ready Answer
Right of withdrawal	Consumer right to return online purchases within cooling-off period	14 days in EU; consumer cannot physically inspect goods online before purchase

FINAL EXAM STRATEGY — CLASSES 07 TO 09

For Class 07: Know the 7 participants in the payment ecosystem and their roles; be able to trace the card authorization flow step-by-step; explain tokenization; compare NFC vs. QR code payments; know BNPL risks; state PCI-DSS goals. For Class 08: The five security dimensions (confidentiality, integrity, availability, authenticity, non-repudiation) with definitions and threats; AES = symmetric, RSA = asymmetric; RSA formula $C = M^e \text{ mod } n$; hash function properties and SHA-256 vs. MD5; digital signature rule (sign with private, verify with public); SSL/TLS handshake steps and role of Certificate Authorities. For Class 09: Define and give examples of phishing, SQL injection, XSS, CSRF, social engineering types; ethical issues (price discrimination, dark patterns, data harvesting) with examples; GDPR vs. CCPA comparison; Bangladesh DSA 2018 key sections; ICT Act and digital signature validity; Consumer Rights Protection Act. The RSA formula and GDPR provisions are almost certain exam content.